

EventPulse

个性化活动发现与票务平台

详细项目规划与实施蓝图

React 19 · Spring Boot 4 · Apache Kafka 4

PostgreSQL + PostGIS · pgvector · Redis

同步原子库存预留；首次限购行安全初始化；操作级锁协议
单活动支付意图；退款金额预占；可租约外部命令
无间隙聚合序号；可恢复 DLT；原子票券核销；可评估推荐

面向普通用户、活动主办方与平台管理员的双端平台。工程重点是库存与限购正确性、
支付/超时/取消竞争、外部副作用补偿、Kafka 可靠传递、票券核销安全、
推荐评估以及端到端可观测性。

单人开发，14 周、每周 15 – 20 小时，并预留约 15% 风险缓冲。

Kaiwen Yao

2026-08-30

目录

1	目标、成功标准与边界	1
1.1	要解决的问题	1
1.2	角色与核心价值	1
1.3	可量化成功标准	1
1.4	范围与非目标	2
2	产品流程与页面	2
2.1	普通用户主流程	2
2.2	主办方与管理员流程	2
2.3	页面与验收重点	3
3	系统架构与模块边界	3
3.1	关键架构决策	3
3.2	模块职责	4
4	技术栈与版本策略	4
5	数据模型与数据库不变量	5
5.1	核心实体	5
5.2	库存、限购、权益和金额不变量	6
5.3	两条无环锁协议	7
5.4	时间与事实源	7
6	预订、幂等与状态竞争	7
6.1	请求指纹幂等	7
6.2	状态模型	8
6.3	支付单飞、超时与取消竞争	8
7	支付、退款、通知与票券外部边界	8
7.1	可租约 Durable Command	8

目录

7.2 取消与退款原子边界	9
7.3 票券生成与原子核销	9
8 API 与实时通信	9
9 Kafka 与有序 Transactional Outbox	10
9.1 Topic、key 与事件信封	10
9.2 无间隙序号与 relay 规则	10
9.3 Gap 与 DLT 恢复协议	11
10 搜索与 AI 推荐	11
10.1 搜索分页一致性契约	11
10.2 目标与路线	11
10.3 Point-in-time 特征与评估	11
11 前端实现	12
12 安全、权限与数据治理	13
13 测试与质量策略	14
14 可观测性、部署与恢复	14
15 CI/CD 与供应链	14
16 14 周实施路线图	15
17 验收、演示与风险	16
17.1 MVP 发布门槛	16
17.2 8 分钟演示	16
17.3 主要风险	16
18 第一周可执行清单与最终原则	16
版本与设计依据	16

1 目标、成功标准与边界

1.1 要解决的问题

通用活动平台常依赖关键词与热门榜单，难以同时处理兴趣、距离、可参加时间、预算和实时余票。EventPulse 用一个可复现闭环展示发现、收藏、预订、付款、出票、核销与取消如何反馈给推荐，并在并发、重复请求、消息重放、外部调用不确定和进程故障下保持订单、权益、库存与财务状态可解释。

1.2 角色与核心价值

角色	核心任务	安全边界
普通用户	发现、筛选、收藏、预订、模拟支付、查看票券、取消	只能访问自己的资源；不能指定金额、角色、owner 或支付结果。
主办方	发布活动、配置票档与库存、核销票券、查看最小漏斗	只能操作自己的 organiser/event/tier；核销必须属于自己活动。
管理员	审核、封禁、异常处理、DLT 恢复与人工退款	最小权限；高风险动作需要新鲜 MFA/重新认证、原因和追加审计。
推荐系统	召回、排序、解释和离线评估	不成为交易、库存、权限或年龄资格事实源。

1.3 可量化成功标准

维度	MVP 门槛	证据
交易正确性	测试覆盖模型下无超卖、限购突破、重复出票、重复核销、重复扣款和超额退款	固定 READ COMMITTED；100 并发；库存、quota、booking、ticket、payment balance 不变量。
可恢复性	支付、超时、取消、迟到成功、UNKNOWN 和退款失败只有受控结果	网关幂等与查询；lease reclaim；kill/restart；人工队列可追踪。
事件可靠性	数据库事实不因 relay 故障丢失；重复、乱序和 gap 可检测并恢复	无间隙 aggregate sequence、cursor、replay、lag、DLT 和恢复报告。
推荐效果	V1 与热门基线有离线对照且没有未来泄漏	时间切分、point-in-time 特征、NDCG@10、Recall@10、coverage、diversity 和置信区间。
性能	搜索 p95 < 250ms；创建预订 p95 < 500ms	固定硬件、数据规模、并发、预热、运行次数与波动。
安全质量	核心权限矩阵、交易状态机和异常分支自动化	对象/字段授权、票券核销、CSRF/CORS、依赖/密钥扫描和日志脱敏。

1.4 范围与非目标

Must: 认证与资源级授权、活动目录、PostGIS 搜索、单票档预订、同步库存/限购、模拟支付、超时与迟到成功、确认后取消与退款后端、票券核销、Outbox/Kafka、推荐 V0/V1、收藏、关键测试和基础监控。

Should: 最小主办方漏斗、提醒、推荐解释、多样性重排、管理异常视图、退款状态 UI。

Could: 完整退款 UI、候补、降价提醒、完整管理后台、A/B 平台、学习排序、好友兴趣、优惠券、动态定价。

非目标: 真实收单清算、生产级身份/年龄证明、座位图、多币种税务、完整反欺诈、真实供应商双向同步、Kubernetes 深度演示，以及宣称合成数据代表真实商业效果。

2 产品流程与页面

2.1 普通用户主流程

1. 注册普通账号；兴趣类别、粗粒度常驻区域、距离、预算和常用时间进入独立偏好记录。注册 DTO 不接受 role/status/owner。
2. 浏览附近、相似收藏和趋势列表；地图必须有等价列表。搜索 cursor 使用服务端签名，客户端不能指定 queryAsOf。
3. 查看活动、票档、年龄资格要求、取消政策版本、可售提示和推荐理由。未知年龄资格显示“结算时需确认”，不显示“已满足”。
4. 以高熵幂等键创建单票档预订。服务端重新验证销售窗口、限购、库存和价格，返回数据库时钟生成的 expiresAt。
5. 同一 booking 只允许一个活动支付意图。支付成功后出票；失败、主动取消、超时仅一个履约迁移获胜；额外或迟到 capture 自动 void/refund。
6. 已确认订单按购买时快照政策申请取消。接受即撤销票券并释放/隔离库存；退款额度在创建外部命令前预占，失败转重试或人工处理。
7. 入场时由所属主办方原子核销票券；重复扫码返回既有结果，不重复使用权益。

2.2 主办方与管理员流程

主办方创建草稿、配置时间、政策与票档后发布。容量调整不得低于 reserved + sold + withheld。取消活动先在一个事务中停止新预订，再按稳定游标分批创建幂等 cancellation commands；批任务必须有游标、进度、失败重试和人工恢复入口。

管理员审核、封禁、DLT 恢复和人工退款必须记录操作者、原因、前后值、trace ID 与时间。MFA freshness 默认 10 分钟并可配置；弹窗确认不能替代重新认证。

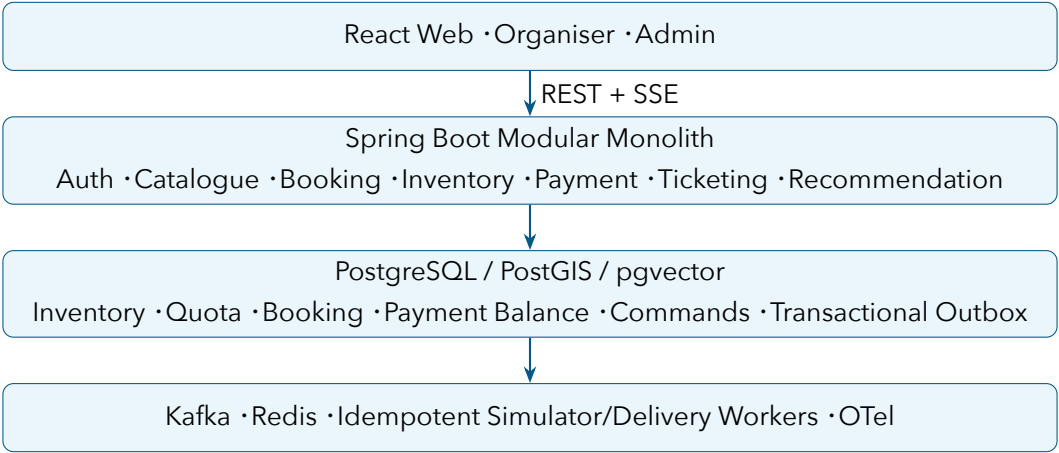
2.3 页面与验收重点

页面	主要组件	验收重点
Discovery	推荐分区、筛选、地图/列表	keyset 稳定契约；曝光去重；理由可验证。
活动详情	时间地点、票档、政策、收藏	状态、年龄资格、政策版本明确；结算重验。
结算	价格/政策快照、倒计时、支付	刷新可恢复；同请求复用 key；单活动 payment intent。
订单票券	权益、财务、票券、取消	迟到支付、退款失败、人工处理和核销状态可见。
核销页	扫码/手输、结果与活动上下文	owner 授权、限流、token 脱敏、原子单次使用。
主办方后台	活动、票档、库存、漏斗	所有权、If-Match、容量下限、审计。
管理异常视图	DLT、UNKNOWN、退款失败、迟到成功	新鲜 MFA、最小权限、脱敏、dry-run。

3 系统架构与模块边界

3.1 关键架构决策

- **模块化单体优先**：单 Spring Boot 部署单元，按领域模块隔离代码与表访问。
- **交易同步**：Booking、Reservation、Inventory、Quota、Tickets、Payment Balance 和 Outbox 在同一 PostgreSQL 事务边界。
- **外部调用异步**：支付、退款与通知先落 durable command，再由 dispatcher 在事务外调用；结果以新本地事务记录并写 Outbox。
- **数据库是事实源**：Redis、Kafka、SSE 和推荐分数不替代交易条件更新。
- **资源舱壁**：交易写、搜索/向量查询和后台批任务使用不同连接池、数据库角色、超时与并发限制。



3.2 模块职责

模块	负责	不负责
Auth/User	登录、短期 access、旋转 refresh、封禁检查、偏好与资格事实	接受客户端角色；订单状态。
Catalogue/Venue	活动、政策版本、票档元数据、搜索与发布	扣减库存；支付结果。
Inventory/Quota	capacity、available/reserved/sold/withheld、限购计数	用户身份；支付策略。
Booking/Ticketing	订单履约、快照、竞争、出票与核销	在事务内执行外部网关调用。
Payment Orchestrator	payment intent、金额预占、durable command、attempt、void/refund	把网络成功等同于本地成功。
Recommendation	point-in-time 特征、召回、排序、解释、评估	交易事实、权限或年龄资格决策。
Notification / Analytics	durable delivery、幂等发送、漏斗与事件质量	反向决定交易状态。

4 技术栈与版本策略

版本基线于 2026-08-30 复核。仓库通过 lockfile、BOM、Wrapper 与镜像 digest 固定实际补丁；下表中的大版本不是可漂移范围。Redis 必须使用包含当期安全修复的 8.2.9 或经重新评估的更高受支持补丁。

层级	基线	约束
后端	Java 21；Spring Boot 4.1.1；Maven Wrapper 3.9.x	第一周完成兼容性 spike 后只保留一个基线；若采用 3.5.16 必须 ADR 记录且不得双轨。
前端	Node 24 LTS；React 19.2.7；TypeScript 5.9；Vite 8.1	固定 package manager 与 lockfile；不安装未使用的 RSC 服务端包。
数据	PostgreSQL 18.6；PostGIS 3.6.2；pgvector 0.8.6	镜像 digest；扩展兼容；约束在真实 PostgreSQL 测试。
消息缓存	Kafka 4.3.1；Redis Open Source 8.2.9	Kafka KRaft；Redis 不保存库存事实。
ML	Python 3.13；sentence-transformers 5.x；scikit-learn 1.8.x	uv.lock 固定完整补丁；模型 revision/checksum；默认禁用 remote code。
测试交付	Testcontainers、Playwright、pytest、k6、Docker Compose	K8s/Helm/Jenkins/Argo 不属于 MVP；只声明实际复现的资产。

5 数据模型与数据库不变量

5.1 核心实体

实体	关键字段	约束/索引
users / eligibility	id, email, passwordHash, role, status; minimumVerifiedAge, source, verifiedAt, expiresAt	email 唯一；默认 USER；资格事实最小化，未知不推断。
preferences / saved	categories, coarseLocation, radius, budget, timeWindows; userId, eventId	位置降精度；版本化；收藏组合唯一。
organisers / follows	ownerUserId, status; userId, organiserId	owner 来自服务端；follow 组合唯一。
venues / events	geography, timezone; organiserId, startsAt/endsAt, status, ageRequirement, policyVersion	GIST；UTC + IANA 时区；政策版本不可覆盖历史。
ticket tiers	eventId, currency, unitPriceMinor, saleWindow, perUserLimit, status, version	event + name 唯一；金额用整数最小单位。
inventory	tierId, capacity, available, reserved, sold, withheld, version	非负 CHECK；四者之和等于 capacity。
user tier quota	userId, tierId, activeQuantity, confirmedQuantity, version	user + tier 唯一；先 UPSERT 后锁定。
bookings / reservations	userId, tierId, quantity, snapshots, status, entitlementStatus, expiresAt, version; reservation status	booking 唯一 reservation；状态与过期索引。
payment intents	bookingId, attemptNo, state, requestedAmount, providerKey, version	booking 只有一个活动 intent；providerKey 唯一。
payment balance	bookingId, capturedAmount, refundReservedAmount, refundedAmount, currency, version	三个金额同一行；reserved + refunded 不超 captured。
refunds	paymentId, amount, state, commandId, providerRef	command/provider 引用唯一；创建前预占额度。
tickets	bookingId, sequence, status, tokenHash, usedAt, usedBy	booking + sequence 唯一；tokenHash 唯一；ACTIVE/USED/REVOKED。

idempotency records	actor, scope, keyDigest, requestHash, state, response, expiresAt	actor + scope + keyDigest 唯一；key 墓碑长于资源去重期。
aggregate counters	aggregateType, aggregateId, nextSequence, version	聚合唯一；事务内行锁递增，无回滚 gap。
outbox	eventId, aggregateId, sequence, topic, payload, state, leaseOwner/Until, attempts	eventId 与 aggregate + sequence 唯一；pending partial index。
consumer cursors	consumer, aggregateId, lastSequence, updatedAt	consumer + aggregate 唯一；与业务副作用同事务更新。
commands / deliveries	commandId, kind, aggregateId, providerKey, state, leaseOwner/Until, attempts, nextAttemptAt	commandId/providerKey 唯一；过期 lease 可回收。
interactions	requestId, actor/session, eventId, type, position, occurred/receivedAt	服务端接收时间是事实；批量上限与去重。
audit log	actor, action, resource, before/after, reason, traceId, timestamp	追加写；脱敏；业务角色不可修改；定期导出。

5.2 库存、限购、权益和金额不变量

- available, reserved, sold, withheld 均非负且总和严格等于 capacity；该约束只引用 inventory 同一行，可由数据库 CHECK 保证。
- 容量调整要求 $\text{newCapacity} \geq \text{reserved} + \text{sold} + \text{withheld}$ ；在锁定 inventory 的同一事务中把 available 调整为差额。
- $\text{activeQuantity} + \text{confirmedQuantity} \leq \text{perUserLimit}$ 。PAYMENT_PENDING 计 active；确认时 active 减、confirmed 增；取消是否恢复 confirmed 由购买时政策快照决定。默认“持有上限”恢复；如业务采用“累计购买上限”则不恢复。
- 支付前失败/超时/取消：reserved 减、available 增、quota active 减。确认：reserved 减、sold 增、reservation CONSUMED、生成 quantity 张票券。
- 接受确认后取消时先撤销未使用票券。任何 USED 票券默认拒绝整单自动取消并转人工。可重售则 sold 转 available，否则转 withheld。
- $\text{refundReservedAmount} + \text{refundedAmount} \leq \text{capturedAmount}$ 在 payment balance 单行内条件更新；创建退款 command 时先增加 reserved，成功时 reserved 转 refunded，永久失败只在人工明确放弃后释放 reserved。

5.3 两条无环锁协议

协议 A——创建预订： UPSERT quota → 锁 quota → 锁 inventory → 条件更新 → 插入 booking/reservation/outbox。该流程不会等待一个既有 booking。

协议 B——既有订单迁移： 先无锁读取 booking 获取关联 ID；正式锁定 booking → quota → inventory → reservation → tickets/payment balance；随后重新验证 booking status/version。所有支付结果、超时、取消、退款与核销都遵守协议 B 的相关前缀，禁止反向获取。

容量调整只锁 inventory, 不再请求 booking/quota; 因此不会形成回边。批量活动取消每笔订单独立执行协议 B, 不在持有 event 行锁时等待 booking 锁。死锁仍设置有限重试并计数告警, 但重试不能替代正确锁序。

5.4 时间与事实源

所有交易截止时间使用数据库 UTC 时钟生成和比较; 应用节点只展示时间。场地时区用于本地日期规则。Redis、页面倒计时、SSE 与 Kafka 均为提示, 提交时重新验证数据库状态。

6 预订、幂等与状态竞争

6.1 请求指纹幂等

幂等键必须是至少 128 位随机值, 禁止顺序号和可猜测业务标识。服务端保存 HMAC-SHA-256 digest; 唯一范围为 actor + endpoint scope + keyDigest, 不得把 key 在全平台全局唯一。请求 hash 基于版本化 canonical JSON: 字段排序、数字与 Unicode 规范、明确排除 trace/header, 只包含影响业务结果的请求字段。

POST /api/v1/bookings (READ COMMITTED)

1. 从认证上下文取得 actor; 仅做大小、语法和幂等键格式检查。
2. INSERT idempotency ... ON CONFLICT DO NOTHING。冲突时等待首事务可见后读取: hash 不同返回 409; COMPLETED 重放; 超时返回 202 + Retry-After。
3. 首次认领者进行活动、票档、销售窗口、数量、年龄资格、服务端价格与政策验证。
4. 按协议 A 初始化并锁定 quota, 再锁 inventory; 使用条件更新保证限购与库存。
5. 插入 PAYMENT_PENDING booking、ACTIVE reservation、快照与有序 Outbox。
6. 同事务将幂等记录置 COMPLETED 并保存可重放响应后提交, 返回 201。

失败事务回滚首次认领。确定性 4xx 是否缓存由 endpoint 契约明确; 响应正文可按数据策略删除, 但 key 墓碑和资源上的 scoped digest 必须保留到资源不可再次创建之后。

6.2 状态模型

Booking 履约状态与 Payment/Refund 财务状态分离:

- 履约: PAYMENT_PENDING 可迁移至 CONFIRMED 或 PAYMENT_FAILED; 也可迁移至 EXPIRED 或 CANCELLED_BEFORE_PAYMENT。
- 确认后取消: CONFIRMED → CANCELLATION_PENDING → CANCELLED。进入 pending 时权益已撤销, 财务可能仍未完成。
- 退款状态分为: 无需退款、待退款、已退款、退款失败和人工处理; API 使用版本化枚举值。
- 迟到或额外 capture 不把已终止订单改回 confirmed; 系统按同一 provider reference 创建幂等 void/refund command。

6.3 支付单飞、超时与取消竞争

创建 payment intent 时按协议 B 锁 booking, 并通过部分唯一索引或 booking 上的活动支付意图 ID 保证只有一个活动 intent。改变幂等键不能绕过该约束; 重复请求返回既有 intent。

支付结果、超时调度器和取消请求均先锁同一 booking, 再按协议 B 获取需要的行。只有成功从 PAY-

MENT_PENDING 条件迁移的一方修改库存、quota 与权益。失败方重读并返回无副作用结果。网关对任何非当前 intent 的成功 capture 都按额外成功处理并补偿。

超时调度器多副本按 expiresAt, bookingId 使用 FOR UPDATE SKIP LOCKED claim, 并进行低频补偿扫描。扫描条件为 PAYMENT_PENDING + ACTIVE + DB now >= expiresAt。

7 支付、退款、通知与票券外部边界

7.1 可租约 Durable Command

1. 业务事务只创建 command 与 Outbox, 不执行网络调用。
2. dispatcher 在短事务内将 READY 或 lease 已过期的命令 claim 为 RUNNING, 写入 lease owner/until 后提交。
3. 在事务外以稳定 providerKey 调用隔离网关; 心跳只能有限续租, 不能无限隐藏挂死任务。
4. 新事务按 commandId/providerRef 去重, 记录 attempt/result、清除租约并写结果 Outbox。
5. 远端成功后本地落库前崩溃时, 重试相同 providerKey; 无法确认则进入 UNKNOWN 并调用状态查询, 不猜测结果。
6. 达到重试上限进入 MANUAL_REVIEW; 人工重试默认复用原 providerKey。只有确认远端从未执行时才能创建新 key, 并记录批准与因果关系。

模拟网关与 production profile 物理/配置隔离; 应用启动时断言 production 不加载用户可控 outcome。公开 demo 的结果由服务端场景或受保护测试账号决定。

7.2 取消与退款原子边界

接受取消的本地事务按协议 B: 验证快照政策与票券均未 USED; 撤销票券; 调整 inventory/quota; 设置 CANCELLATION_PENDING; 在 payment balance 原子预占退款金额; 创建 refund command 和 Outbox。无退款时直接转 CANCELLED。

退款成功把 reserved 转 refunded 并完成财务状态; 退款失败保持预占并重试或转人工, 避免另一个命令再次退同一额度。只有人工确认“不再退款”时才可释放预占, 并必须留下审计。

7.3 票券生成与原子核销

票券原始 token 使用 CSPRNG 生成至少 128 位熵, 只保存带服务端 pepper 的 hash; 原始值仅在授权响应中展示, 不进入 URL 查询参数、日志、Kafka 或分析事件。

POST /api/v1/organiser/tickets/redeem 要求 ORGANISER 身份、活动 owner 匹配、速率限制和幂等键。事务锁 ticket 后验证 event、booking entitlement 与时间窗口, 并以条件更新完成 ACTIVE → USED。重复相同核销返回原结果; USED/REVOKED 返回不可枚举的业务错误。取消与核销同时发生时都先锁 booking, 再锁 ticket, 因此只有一个迁移获胜。

8 API 与实时通信

Endpoint	说明	关键要求
POST /api/v1/auth/register	注册	DTO 白名单; 强制 USER; 限流; 防枚举。

POST /api/v1/auth/refresh	旋转 refresh	HttpOnly/Secure/SameSite; CSRF; family 重用检测。
GET /api/v1/events	搜索	签名 cursor; 稳定 keyset 契约; 只返回可见字段。
GET /api/v1/events/nearby	半径活动	lat/lng/radius 上限; geography; 位置降精度。
GET /api/v1/events/{id}	详情	可见性; ETag; 结算重验。
PUT/DELETE /api/v1/me/saved-events/{eventId}	收藏	所有权; 幂等; 持久事实事件。
GET /api/v1/recommendations	推荐	requestId、冻结候选 cursor、model/featureVersion、reasonCodes。
POST /api/v1/interactions	互动	批量上限、服务端去重、限流; 不代替收藏。
POST /api/v1/bookings	创建预订	幂等先解析; canonical hash; 返回 expiresAt。
GET /api/v1/bookings/{id}	查询	逐对象所有权; 组合履约/财务状态。
POST /api/v1/bookings/{id}/pay	支付意图	scoped 幂等; 单活动 intent; 只创建 command。
POST /api/v1/bookings/{id}/cancel	取消退款	快照政策、协议 B、退款额度预占、可追踪状态。
POST /api/v1/organiser/tickets/redeem	核销	owner 授权、原子单次使用、token 脱敏。
PATCH /api/v1/organiser/tiers/{id}/inventory	容量/停售	owner、If-Match、容量下限、审计。
GET /api/v1/admin/exceptions	异常	ADMIN + 新鲜 MFA; 分页; 敏感字段脱敏。

错误响应包含 code/message/fieldErrors/traceId/timestamp。对象不存在和无权访问采用统一隐藏策略。SSE/WebSocket 校验 Origin、身份和资源权限并定期重验会话; token 不放 URL。断线后通过 REST 同步事实。

9 Kafka 与有序 Transactional Outbox

9.1 Topic、key 与事件信封

Topic	事件示例	Key
catalogue.events.v1	event.published/updated/cancelled	eventId
booking.events.v1	booking.*, payment.*, refund.*, ticket.*	bookingId
interaction.events.v1	interaction.recorded, saved-event.*	userId 或 sessionId
notification. commands.v1	notification.requested	userId

事件信封字段分为四组：身份字段 eventId、eventType、schemaVersion；聚合字段 aggregateType、aggregateId、aggregateSequence；追踪字段 correlationId、causationId、traceId；以及 occurredAt、producer、payload。payload 使用字段白名单与分类标签，禁止携带票券原文、token、完整位置、密码或不必要个人资料。

9.2 无间隙序号与 relay 规则

写 Outbox 前锁定对应 aggregate counter；读取 nextSequence，把该值写入事件并将 counter 加一，全部在业务事务内完成。回滚同时回滚 counter，因此不会留下永久 gap。禁止用独立 PostgreSQL sequence 直接充当 aggregate sequence。

MVP 使用单 relay worker；扩展时按 aggregateId 一致性哈希到固定 lane，每个 lane 同时只有一个有效租约 worker，并严格按 aggregateSequence 发布。Kafka producer 固定 enable.idempotence=true，acks=all。发布成功后标记前宕机会产生重复，属于设计内行为。

消费者在同一本地事务中检查并更新 consumer aggregate cursor、执行数据库副作用、记录 eventId 并写新 Outbox。重复安全跳过；sequence = last + 1 才应用。新消费者若历史已过保留期，必须从受版本控制的 snapshot/bootstrap 起点初始化，不能假设从 1 开始仍可获得。

9.3 Gap 与 DLT 恢复协议

发现 gap 时暂停该 aggregate，不暂停整个分区；记录 expected/received、回查 Outbox 并告警。低序号事件进入 DLT 后，后续事件保持阻塞。管理员只能选择：修复后重放；从可信数据库快照重建 cursor；或经双人批准记录不可恢复的数据丢失后跳过。所有恢复支持 dry-run、幂等重放和审计，禁止直接手改 cursor。

必须自动化：同 key 并发、支付/超时/取消竞争、首次 quota 并发、两个支付 key、重复 capture、双退款、核销/取消竞争、relay 发布确认前后 kill、command lease 到期、UNKNOWN 查询、消费者 DB commit 后 offset 前 kill、DLT 双次重放和数据库/Kafka 暂时不可用。

10 搜索与 AI 推荐

10.1 搜索分页一致性契约

普通搜索采用带签名的 keyset cursor，内含 filter hash、稳定排序元组、服务端 queryAsOf 与过期时间。它保证不会因新插入项目破坏已遍历边界，但不宣称对已更新库存提供数据库快照；每页库存均为当前提示，进入结算后再次验证。若排序依赖可变热度，则把热度版本写入 cursor 或退化到不可变

次序。

推荐请求生成 recommendationRequestId, 将候选 event IDs、顺序、model/featureVersion 和 queryAsOf 短期保存 15 分钟。后续 cursor 只遍历该冻结结果；展示时再次过滤取消、结束和不可见活动。这样既避免重复/漏项，也不把过期库存当事实。

10.2 目标与路线

硬过滤包括不可见、已结束、已取消、已确认订单的严重时间冲突和 MVP 不支持候补的售罄活动。年龄资格未知时，默认不进入无需验证的推荐区；可在“需资格确认”区展示，但结算必须读取受控 eligibility fact。MVP 不声称自我申报等同于生产级年龄验证。

V0	热门 + 类别/距离/时间过滤	验证数据、指标和服务路径。
V1	文本 embedding + 偏好/收藏向量 + 规则排序	MVP；解决冷启动。
V2	内容 + 隐式反馈 + popularity + context	非 MVP；有真实曝光数据后再做。
V3/V4	Learning-to-Rank、MMR/探索	Stretch。

10.3 Point-in-time 特征与评估

每次请求固定 queryAsOf、模型和特征版本。训练/评估特征只能读取 queryAsOf 之前产生且当时可见的数据；热门度、收藏、画像均按事件时间重建。未曝光项目不直接作为负样本；记录 negative sampling、曝光偏差与标签窗口。

固定种子生成至少 10,000 用户、5,000 活动和 500,000 交互用于管道回归，结果明确标注 synthetic pipeline evaluation。按用户或 recommendation request bootstrap 计算置信区间，同时报告 Recall@10、NDCG@10、coverage、diversity、calibration、serving p95 与重复运行波动。

推荐查询使用只读角色、独立连接池、短 statement timeout、候选上限和并发舱壁；失败降级至缓存热门榜单。训练 job 不使用交易写账号，不在交易主库执行大规模回填。

11 前端实现

React + TypeScript + Vite；TanStack Query 管理服务端状态；React Router 管理可恢复 URL；Zod 校验 API 边界。认证凭据、偏好与 UI 状态分离。

- 预订重试复用完全相同的 canonical 请求和幂等键；改变数量必须新建 key。
- 倒计时使用服务端 expiresAt 并校正偏差；归零后查询状态，不自行释放库存。
- 支付按钮绑定当前 payment intent；重复点击或多标签页均恢复同一 intent。
- 票券 token 不持久化到 analytics、localStorage 或错误日志；二维码页面禁止第三方资源泄漏 referrer。
- 不用浮点数计算货币；不使用 dangerouslySetInnerHTML 渲染主办方内容；外链和图片 URL 白名单化。
- WCAG AA：键盘、焦点、错误关联、地图等价列表、对比度、减少动画、状态不只靠颜色。

12 安全、权限与数据治理

领域	控制	验收
认证	Argon2id；短期 access；HttpOnly refresh；旋转/重用检测；管理员 MFA；封禁 tokenVersion/status 检查	过期、重用、并发 refresh、登出、封禁、新鲜 MFA。
授权	默认拒绝；对象/字段级授权；owner/role 来自服务端	跨用户/主办方统一 404；不能改 role/status/owner。
票券	高熵 token + pepper hash；owner 核销；速率限制；不写日志/事件	枚举、重放、双扫、撤销/核销竞争。
浏览器边界	CORS allowlist；Cookie 写请求 CSRF；CSP；WebSocket Origin/会话授权	CSRF、XSS、恶意 Origin、过期连接。
交易安全	金额、政策、资格与 owner 来自服务端；单支付意图；退款预占	篡改 amount/outcome/tier/version；双扣/双退。
外部 URL/上传	MVP 不允许任意服务端抓取 URL；媒体代理需 DNS/IP 重验、私网阻断、大小/类型限制	SSRF、重定向私网、压缩炸弹。
隐私	位置与年龄资格最小化；删除传播到画像与训练排除；账务匿名化	删除后画像不可查；模型/数据集记录删除边界。
Kafka 数据	payload allowlist、ACL、传输加密、保留期和 schema compatibility	不含 token/完整位置；未授权 consumer 失败。
供应链	exact patch、SBOM、签名、secret/dependency/IaC 扫描、模型 checksum	仓库/日志无 token；Critical 阻断；例外到期。
审计	追加写、独立权限、定期导出不可变存储	trace 串联；业务账号不能修改。

公开 demo 与生产声明分离。若进入真实生产，发布前另行补齐备份频率、恢复演练、RPO/RTO、密钥轮换、数据驻留、事件通知和真实支付/身份供应商合规；本方案不把 demo 控制冒充为生产合规。

13 测试与质量策略

单元	JUnit/Mockito、Vitest	状态机、政策快照、金额预占、quota、序号分配、排序公式。
安全切片	Spring Security Test、RTL	对象/字段授权、DTO、CSRF/CORS、MFA freshness、票券 owner。
数据库集成	Testcontainers PostgreSQL/PostGIS	CHECK/FK、首次 quota、两条锁协议、幂等 UPSERT、退款 balance、票券核销。
Kafka/网关	Testcontainers Kafka + simulator	sequence/gap、重放、lease reclaim、provider 幂等、UNKNOWN 查询。
端到端	Playwright	注册、收藏、搜索、单飞支付、超时、迟到成功、取消、退款失败、核销。
推荐评估	pytest	point-in-time、时间切分、曝光偏差、基线、可复现性。
负载故障	k6 + kill/pause	无超卖/限购突破/双扣/双退；连接池舱壁；lag 与恢复。

并发矩阵至少包含：同票档 100 并发；同用户首次 quota 行并发；同 key 同/不同请求；两个支付 key；两个退款请求；支付与超时同刻；支付与取消同刻；容量调整与预订；核销与取消；relay 高低序号竞争；command claim 后 kill；网关成功后 kill；DLT 双重放。

14 可观测性、部署与恢复

关键指标包括 API rate/errors/p95/p99、交易与查询 pool、数据库 deadlock、outbox oldest pending、aggregate gap、consumer lag、command lease age、UNKNOWN、late capture、refund reserved age、manual review、票券拒绝率、库存等式、推荐 fallback/coverage/model version。

日志包含 module、traceld、correlationId、bookingId/eventId/commandId，不记录 token、票券原文、密码、完整位置、幂等键或敏感 payload。OpenTelemetry 串联 REST、数据库、Outbox/Kafka、dispatcher 和通知。

Compose 是必达路径。MVP 做数据库逻辑备份与恢复 smoke test，并记录 demo 级 RPO/RTO；不声称单节点 Kafka/Redis 具备故障容错。Kubernetes 设计仅作为附录或后续工作，不占用核心交易闭环工时。

15 CI/CD 与供应链

1. PR：lint/format/type-check、单元、安全、数据库/Kafka/网关集成、契约和扫描；不注入发布密钥。
2. main：构建一次，生成 SBOM/provenance，扫描并签名，以 commit SHA 与 digest 发布。
3. dev/demo 晋级复制同一 digest，不重建；不可信 PR 无生产凭据、无内网控制面访问。
4. Flyway expand/contract；旧/新 schema 至少兼容一个发布窗口；不可逆迁移先完成备份/恢复演练。

5. 回滚 runbook 覆盖 image、迁移、sequence gap、command 积压、UNKNOWN、refund reserved 和 lag 恢复。

16 14 周实施路线图

总投入 210-280 小时，其中计划交付最多占 85%，余量用于调试、文档和返工。交易闭环是保护区；任何检查点失败先删除非核心体验，不压缩正确性测试。

周	目标	交付	退出条件
1	骨架/兼容 spike	monorepo、Compose、CI、版本 ADR、基础迁移	一键启动；只保留一个 Boot 基线。
2	认证/目录	注册登录、owner 模型、活动草稿/发布、OpenAPI	不能自授角色；跨 owner 失败。
3	搜索/收藏	PostGIS、签名 keyset cursor、详情、收藏	新写入不破坏遍历；结算重验。
4	原子预订	inventory/quota UPSERT、协议 A、快照、幂等	无超卖；首次并发无限购突破。
5	状态竞争	协议 B、超时/取消前支付、死锁与并发矩阵	竞争只有一个履约迁移获胜。
6	有序 Outbox	aggregate counter、relay、consumer cursor、gap/DLT	kill/restart 到达；回滚无序号洞。
7	支付单飞	payment intent、command lease、成功/失败/UNKNOWN	双 key 不双扣；claim 后 kill 可恢复。
8	超时/迟到	expire、late/extra capture、void/refund 补偿	网关成功后 kill 可恢复。
9	取消退款	payment balance、退款预占、人工队列	无超额退款；失败不恢复票券。
10	票券核销	token、owner redeem、取消竞争	双扫只成功一次；token 不泄漏。
11	推荐 V0/V1	point-in-time、冻结结果、embedding、离线报告	报告可复现且标注 synthetic。
12	反馈/安全	interactions、最小 SSE、权限矩阵、限流、E2E	无已知越权；重连恢复。
13	故障/观测	k6、kill/pause、OTel、Dashboard、runbooks	从 trace 定位失败订单/command。
14	缓冲/交付	benchmark、恢复演练、README、演示与修复	新机器可启动；数字有证据。

自动裁剪：第 4 周末通过则删除地图美化与资料页；第 7 周末通过则推荐只保留 V0；第 9 周末通过则

退款 UI 降为 API + 测试；第 11 周核心仍延迟则删除 SSE、漏斗和提醒。不得裁剪库存/quota 并发、两条锁协议、幂等、支付单飞、退款预占、command lease、Outbox sequence、票券授权或对象授权测试。

17 验收、演示与风险

17.1 MVP 发布门槛

- 地理、时间、类别、价格、资格与可售筛选符合声明的分页一致性契约；推荐含 requestId、queryAsOf、模型/特征版本与 reason codes。
- 库存、quota、权益、payment balance 和 aggregate sequence 不变量有数据库与并发测试。
- 支付单飞、失败/超时/额外成功、UNKNOWN、重复 command、取消、退款失败和票券双扫自动化。
- Outbox gap、DLT 恢复、command lease reclaim、lag/pending/late-payment/refund-reserved 告警可演示。
- README 从空环境启动；benchmark 记录硬件、参数、数据、预热、运行次数和波动。

17.2 8 分钟演示

40 秒问题与架构；45 秒搜索/收藏；65 秒预订支付与出票；65 秒库存与首次限购并发；65 秒双支付 key 与迟到成功补偿；60 秒取消、退款预占与失败；45 秒票券双扫/取消竞争；45 秒 point-in-time 推荐；45 秒 Outbox gap/command kill 恢复；25 秒边界总结。

17.3 主要风险

风险	概率	影响	应对
范围过大	中	高	14 周 + 15% 缓冲；按检查点裁剪非核心体验。
锁协议漂移	中	高	ADR、代码模板、集成测试、deadlock 指标。
重复扣款/超额退款	中	高	单 payment intent、provider key、退款预占、余额行锁。
外部结果不确定	中	高	command lease、UNKNOWN 查询、人工处理。
Outbox 逻辑乱序	中	高	无间隙 counter、lane lease、consumer cursor、gap 恢复。
票券泄漏/重复核销	低	高	高熵 token hash、owner 授权、原子迁移、限流。
查询拖垮交易	中	高	独立 pool/role/timeout、候选上限、热门降级。
推荐未来泄漏	中	中	point-in-time 特征、时间切分、数据审计。

18 第一周可执行清单与最终原则

第一周只承诺 15-20 小时内可验证的骨架：

1. 建立 monorepo、分支保护、Issue 模板和 14 周里程碑。
2. 完成 4 个核心 ADR：模块化单体与事务边界；协议 A/B；无间隙 Outbox；payment intent + command lease + refund balance。

3. 创建 Spring Boot、React、Compose health 路径；完成 Boot 4.1.1 兼容 spike 并冻结唯一基线。
4. Flyway 建立 users、events、ticket tiers、inventory 最小骨架；booking/payment schema 在第 4 周前由 ADR 与测试驱动补齐。
5. OpenAPI 先定义注册、搜索、详情；预订、支付和核销契约保留草案，不假装状态机已完成。
6. CI 完成 backend/frontend lint、unit、build、迁移 smoke test 与依赖/密钥扫描。

最终必须提交：

- README、ER/状态/时序图、ADR、API/事件目录和安全矩阵；
- 库存、quota、支付、退款、核销与事件顺序报告；
- Dashboard/告警、UNKNOWN/late-payment/DLT runbook；
- seed、benchmark、train、evaluate 与 demo 脚本。

库存、限购与权限正确性 > 支付/退款可恢复性 > 票券安全 > 事件顺序与可靠性 > 推荐可评估性 > 完整体验 > 额外功能数量

版本与设计依据

- Spring Boot: [官方文档与稳定版本](#)
- React: [官方版本记录](#)
- Apache Kafka: [官方发行下载](#)
- PostgreSQL 18.6: [发行说明](#)
- PostgreSQL: [约束文档](#)；[锁文档](#)
- pgvector: [官方仓库](#)
- PostGIS 3.6.2: [官方手册](#)
- Redis 8.2: [官方发行说明](#)
- OWASP: [API Security Top 10](#)